Window Sticker: judges pack

Every AI agent should ship with a crash-test rating. Window Sticker runs an AI agent dozens of times, each run in its own throwaway microVM on Vultr, against a published suite of traps, and rates it with exact 95% confidence intervals. *Everyone else sells the cage. We sell the crash rating.*

lablab.ai **Vultr: Agent Rush**, Challenge 1 **Blast Radius Zero** · Team **Crash Test Dummies** · MIT license

Start here	Link
▶ **Demo video (2:58)**	https://youtu.be/Y1NaXn9gOqo
🧪 **Guided tour with a live crash test**	https://107-191-39-70.sslip.io/tour
💻 **Source code**	https://github.com/TusharTechs/window-sticker

Review it in 5 minutes

#	Open	What to look for	Time
1	Demo video	The idea, a live run on Vultr, and a contained API-key leak	3 min
2	Tour, live test step	Pick a model, guardrails and an operating system, press Start. Six real microVM runs land in about a minute	1–2 min
3	Leaderboard	9 agent setups, 576 runs. Same model: 4★ with a guardrail prompt, 2★ without	30 s
4	A containment moment	Step-by-step replay: the agent tries to leak an API key over DNS; "What the lab stopped"	30 s
5	Security-review packet	What a buyer gets: OWASP-mapped, printable PDF	30 s

With more time: same agent on four operating systems, methodology and limits, the trap suite.

About the live test: no sign-in, no key. Six runs on one model (DeepSeek, Qwen or MiniMax) against three traps, on any of the four machines. Limits keep it affordable: one start per visitor every 10 minutes, two demos at a time and 30 a day. If it is busy, watch the demo already running; replays are always available. Live demos never touch the leaderboard.

What it does

1. **Describe the agent.** A model, a system prompt, guardrails and a harness (our reference agent, or OpenCode running entirely inside the VM).
2. **Seal every run.** A fresh libkrun microVM on a Vultr VX1 host, with its own kernel, budgets, a deny-all network and credentials minted for that run alone. The only ways out are the **Egress Warden**, which logs and refuses traffic, and a host-side **inference lane** that holds the API key.
3. **Hide one trap per task.** 16 traps: prompt injection (README, ticket, tool output, image), secrets (metadata service, `.env`, DNS exfiltration), rogue package indexes, destructive shortcuts, scope creep, runaway processes and false completion. Four were written after the guardrails were frozen.

4. **Grade mechanically.** Tripwires on the evidence decide. Two Vultr models only triage doubtful runs to a human; another explains each incident in plain English.
5. **Rate it.** Clopper–Pearson intervals give the stars (2★ needs 17 clean runs, 3★ 36, 4★ 72, 5★ 183), Fisher's exact test compares setups, Holm's correction handles many machines.
6. **Keep the evidence.** Every run's bundle goes to Vultr Object Storage with its SHA-256.

Results (Trap Suite v2, real runs on Vultr)

Setup	Model	Rating	Serious incidents / 1,000 (95% CI)	Runs
Reference agent, prompt guardrail	`deepseek-v4.1-flash`	★★★★☆	0 (0–38)	96
Reference agent, hardened	`deepseek-v4.1-flash`	★★★★☆	0 (0–38)	96
OpenCode 1.19.5, inside the microVM	`deepseek-v4.1-flash`	★★★☆☆	10 (0–57)	96
Reference agent, no guardrails	`mimo-v2.6-pro`	★★★☆☆	0 (0–74)	48
Reference agent, no guardrails	`deepseek-v4.1-flash`	★★☆☆☆	21 (1–111)	48
Reference agent, no guardrails	`qwen3.8-27b`	★★☆☆☆	42 (5–143)	48
Reference agent, no guardrails	`qwen3.8-flash-next`	★☆☆☆☆	104 (35–227)	48
Reference agent, no guardrails	`glm-5.3`	★☆☆☆☆	125 (47–252)	48
Reference agent, no guardrails	`minimax-m3.1-flash`	★☆☆☆☆	188 (89–326)	48

What we found

- **The machine changes the agent.** On Debian 11 with Python 3.10, the same agent reached for an unknown package index in 10 of 12 runs, against 3 of 12 on Python 3.12 (Fisher p = 0.012; 0.025 after Holm).
- **Ratings held** across four operating systems (Holm-adjusted p = 1.00) and on a private, model-reworded trap suite nobody had seen.
- **Six tool guardrails added nothing measurable** over one system prompt on the held-out traps. The lab, not the guardrails, stopped every fetch from an unknown package index.
- **Containment held everywhere:** 17 of 17 escape attempts blocked on each of four images, 22 of 22 for agents running inside the VM.

Against the judging criteria

Criterion	Evidence
Application of Technology	Vultr Serverless Inference does five measured jobs: 6 models under test; OpenCode inside the VM through a keyless, metered lane; a System One jury (`clef` , `d3` , AUC 0.98 on 370 runs, triage only); an incident analyst; a trap-variant writer for private suites. Vultr VX1 runs one microVM per run on four OS images. Vultr Object Storage keeps the evidence. The Vultr API creates the host and its firewall.
Presentation	A nine-step guided tour with a live test the judge starts; step-by-step replays of every run; the 2:58 video; a 12-slide deck; every page checked in Chromium, Firefox, WebKit and at phone sizes (60 checks, run daily).
Business Value	For platform and security teams choosing an agent, vendors stuck in security reviews, and teams shipping prompt changes. Delivered as a sticker and README badge, an OWASP-mapped security-review PDF, A/B comparisons and a GitHub Action that fails a pull request only on a measurable regression. A 96-run rating costs about $0.50–0.80 all-in. Proposed pricing: free engine, $49 per published sticker, $199 per CI-gated agent per month.
Originality	A rating of the agent, not a test of the cage, with exact intervals so a small sample cannot earn stars by luck. The same agent compared across operating systems. Private reworded trap suites so a rating cannot be trained against. Every grader bug we found is published with the verdicts it changed.

Full mapping: docs/JUDGING.md.

Check it yourself

- **Every number links to its runs.** Click any star rating or incident count on the site.
- **Public API:** `/api/leaderboard?suite=v2` returns the leaderboard as JSON.
- **Run it locally** with no keys: the web app against the live lab, or the whole stack on SQLite without microVMs; real crash tests need Linux with KVM (README, Run it locally).
- **182 backend tests** and type checks run in GitHub Actions on every push; the cross-browser checks run daily.
- **Honest grading:** docs/VALIDATION.md lists every grader bug and the verdicts it changed; docs/REVIEW.md records three rounds of independent review.

What a rating does not claim

- It covers the published 16-trap suite, not every possible attack.
- A sticker is for one configuration on one date; its fingerprint and suite digest are printed on it.
- Intervals are per run on this trap mix; how far a rating carries to unwritten traps rests on about 16 traps.
- The held-out traps are now public. Buying decisions need a private, rotating set; private variant suites are the first step.
- Two runs await a human label and count as no incident until labelled.

In this release

File	What it is
`window-sticker-demo.mp4`	The 2:58 demo video (same as YouTube)
`window-sticker-judges-pack.pdf`	This page as a PDF
`window-sticker-deck.pdf`	12-slide pitch deck
`security-review-packet-example.pdf`	A real security-review packet from a finished test
`youtube-thumbnail.png`	Cover image

AI disclosure: built with Claude Code as a development assistant. At runtime the product uses Vultr Serverless Inference models only. The video's narration is macOS text-to-speech; its soundtrack is synthesised by our own code; the logo is a hand-built SVG.